LEXIGRID

Risk Email Automation and Recovery

Version 5.54.15 | Reviewed 2026-11-11

Shahryar Jahangir, Aniza Inc.

Procedures, examples, verification and operational limits. Complete commissioning on your deployment before serving customer traffic. Sample values are fictional; original keys and data must be preserved.

Contents

Risk email automation and receipts **3**

Before you begin . . . 3

Automatic risk updates . . . 3

Scheduled reminders . . . 3

Delivery and read receipts . . . 3

Operational notes . . . 4

Workflow decisions and delivery recovery **4**

Review a governed record . . . 4

Inbox and overdue checks . . . 4

Channel retry and manual recovery . . . 4

Exact content and author independence . . . 5

Risk email automation and receipts

Author: Shahryar Jahangir, Aniza Inc.

Before you begin

Configure `LEXIGRID_SMTP_HOST`, `LEXIGRID_SMTP_FROM`, `LEXIGRID_SMTP_PORT`, `LEXIGRID_SMTP_SECURITY`, and optional `LEXIGRID_SMTP_USERNAME` / `LEXIGRID_SMTP_PASSWORD` in the application environment. Set `LEXIGRID_MAIL_WORKER=1` on designated worker processes. Concurrent workers require the shared PostgreSQL topology and the original shared mail configuration key. For PostgreSQL, run `alembic upgrade head`; preserve the existing database. Apply current migrations for installed databases; development bootstrap must not substitute for an approved installed upgrade.

Automatic risk updates

1. Open **Risks -> Manage -> Stakeholders & Email**. Add recipients and check **Receive email updates**.

2. Open **Email automation & receipts**. A tenant administrator can enable or disable automatic change emails.

3. Edit a risk and save it, or formally close the risk. An email for each opted-in address is queued within the same transaction.

4. The mail worker sends queued notifications over TLS SMTP and records acceptance or retry status. A failure to send does not roll back the risk update.

Example: changing likelihood from 4 to 3 queues an `updated` message containing the risk ID, score, status, and changed field names. Sensitive old/new values are not sent.

Scheduled reminders

Open **Risks -> Manage -> Email automation & receipts**, enter a repeat interval (1-365 days), enable reminders, and save. The worker checks every minute. It sends reminders to opted-in recipients for open risks only. Closing a risk stops reminders without deleting the schedule.

Delivery and read receipts

The notification history distinguishes **queued**, **sending**, **retry**, **failed**, and **smtp_accepted**. SMTP acceptance does **not** prove inbox delivery. Provider-verified delivery confirmations are supported through an **optional HMAC-signed gateway adapter** at `POST /api/notifications/provider-events`. Set `LEXIGRID_MAIL_WEBHOOK_SECRET` (minimum 32 characters), then have your trusted SMTP provider adapter POST JSON `{"tenant_id":"<tenant UUID>","notification_id":"<mail UUID>","event":"delivered"}` or `"bounced"`, with headers `X-LexiGrid-Timestamp` (Unix seconds) and `X-LexiGrid-Signature` (hex HMAC-SHA256 of `timestamp + "." + raw_body`). Use the X-LexiGrid-Tenant-ID header and the UUID in Message-ID to correlate outgoing messages. Adapters using the earlier payload must add tenant_id before enabling callbacks after the upgrade. If the callback returns HTTP 409 with "SMTP acceptance not recorded; retry later", retry with a fresh timestamp and signature. Repeated matching delivery or bounce events are safe. The adapter must be configured for your provider; generic SMTP does not supply delivery receipts.

Read receipts use **explicit authenticated acknowledgment**: a recipient who has a LexiGrid account with the same email and access to the risk can select **Acknowledge read** in the notification history. The system records that user action, not an invisible tracking pixel. External stakeholders without accounts cannot issue a read acknowledgment in this release.

Operational notes

- The background worker is opt-in. Without `LEXIGRID_MAIL_WORKER=1`, notifications remain queued.

- PostgreSQL workers support concurrent exclusive claims, ten-minute lease recovery and stale-attempt fencing. SQLite is for local evaluation, not a multi-host topology. High-volume production throughput remains to be qualified.

- Email is sent to each recipient individually; no other recipient addresses are disclosed.

- Review SMTP error types in the notification history. Browser-managed SMTP credentials are encrypted in the database; the API never returns the password. Preserve the original shared mail configuration key.

For a failed risk email, a tenant administrator or risk manager can open **Email automation & receipts** and select **Retry one delivery attempt**. Supply a reason after correcting the delivery problem. The recipient must still be opted in. Each request grants one extra attempt and records the actor and reason. The attempt counter keeps increasing so earlier workers cannot complete a newer attempt. An expired lease can mean the earlier message was already accepted by SMTP, so recovery can produce a duplicate.

Workflow decisions and delivery recovery

Review a governed record

Create/publish a workflow definition with designated approvers and optional due dates. Start a run for the exact record and target state. A run snapshots approver steps and the reviewed content digest/version. The initiator cannot approve their own run, and only the assigned approver can decide a step. A stale version or resolved run is a conflict, not permission to repeat an approval.

After required decisions complete, retry the governed transition. Approval consumption and transition are atomic and single-use. Changing material record content invalidates the prior approval. An unrelated/legacy approval does not authorize the transition. Check decision history for the actual step and actor, not merely the final state label.

Inbox and overdue checks

The workflow inbox shows the user's own notifications and channel status. Mark read records reading in the application; it is not SMTP delivery confirmation. Tenant administrators may trigger overdue checks. The independent scheduler runs periodic escalation/delivery; native startup alone does not install that scheduler.

Channel retry and manual recovery

Enabled webhook/email channels have separate durable states: queued, sending, retry, retry_requested, failed or delivered. Automatic delivery stops after five attempts, using 2/4/8/16-minute failure backoff and a ten-minute lease. A successful channel is not resent when another channel fails. Disabled channels keep their state until re-enabled.

After correcting the transport issue, a permitted tenant administrator/risk manager may use Failed workflow deliveries to request one additional attempt with a reason and current attempts. Platform administrators act within the selected tenant. A stale/concurrent request returns 409; refresh first. Attempts never reset, and the retry event is audited in the same transaction.

An expired sending lease can mean remote acceptance already occurred. Message-ID/Idempotency-Key stays stable, but the guarantee is at least once. Use receiver deduplication and inspect gateway evidence before manually retrying a suspected accepted message. Do not delete failures or rewrite audit history to hide retries.

Exact content and author independence

, creators, recorded editors and identified owners cannot approve the target through another workflow initiator. Each approval step rechecks the reviewed content digest/version before deciding, in addition to the existing check before consumption. Reject a stale pending run and start a fresh review. Native risk/policy/finding requests also carry exact-content bindings; stale or legacy unbound approvals cannot authorize new actions. Risk acceptance has its own independent decision and mandatory UTC expiry in the Risk Acceptance workspace.